

Relazione Progetto S10L5

Configurazione, Gestione e Verifica di Gruppi e Permessi in Active Directory

Dominio: Epicode.local

Server: EpicodeServer — Windows Server 2022

1. Introduzione

La presente relazione descrive l'implementazione e la configurazione di un'infrastruttura di gestione degli utenti e dei permessi basata su Active Directory (AD), realizzata sul dominio Epicode.local ospitato sul server EpicodeServer (Windows Server 2022).

L'obiettivo del progetto è stato quello di suddividere gli utenti aziendali in gruppi distinti, applicando rigorosamente il principio del minimo privilegio, al fine di garantire la sicurezza dei dati, la stabilità dei sistemi e la corretta compartimentazione delle risorse tra i diversi reparti.

Nello specifico, il lavoro ha previsto: la verifica dei permessi amministrativi necessari, la creazione di due gruppi di sicurezza con relativi utenti di prova, l'assegnazione di permessi differenziati su file, programmi, impostazioni di sistema e accesso remoto, e infine la verifica pratica della corretta applicazione di tali permessi.

2. Verifica dei Permessi Amministrativi

Prima di procedere alla creazione dei gruppi, è stato verificato l'accesso alla console "Active Directory Users and Computers" con un account dotato di privilegi di amministratore di dominio, condizione indispensabile per poter creare, modificare ed eliminare oggetti (utenti, gruppi, unità organizzative) all'interno del dominio Epicode.local.

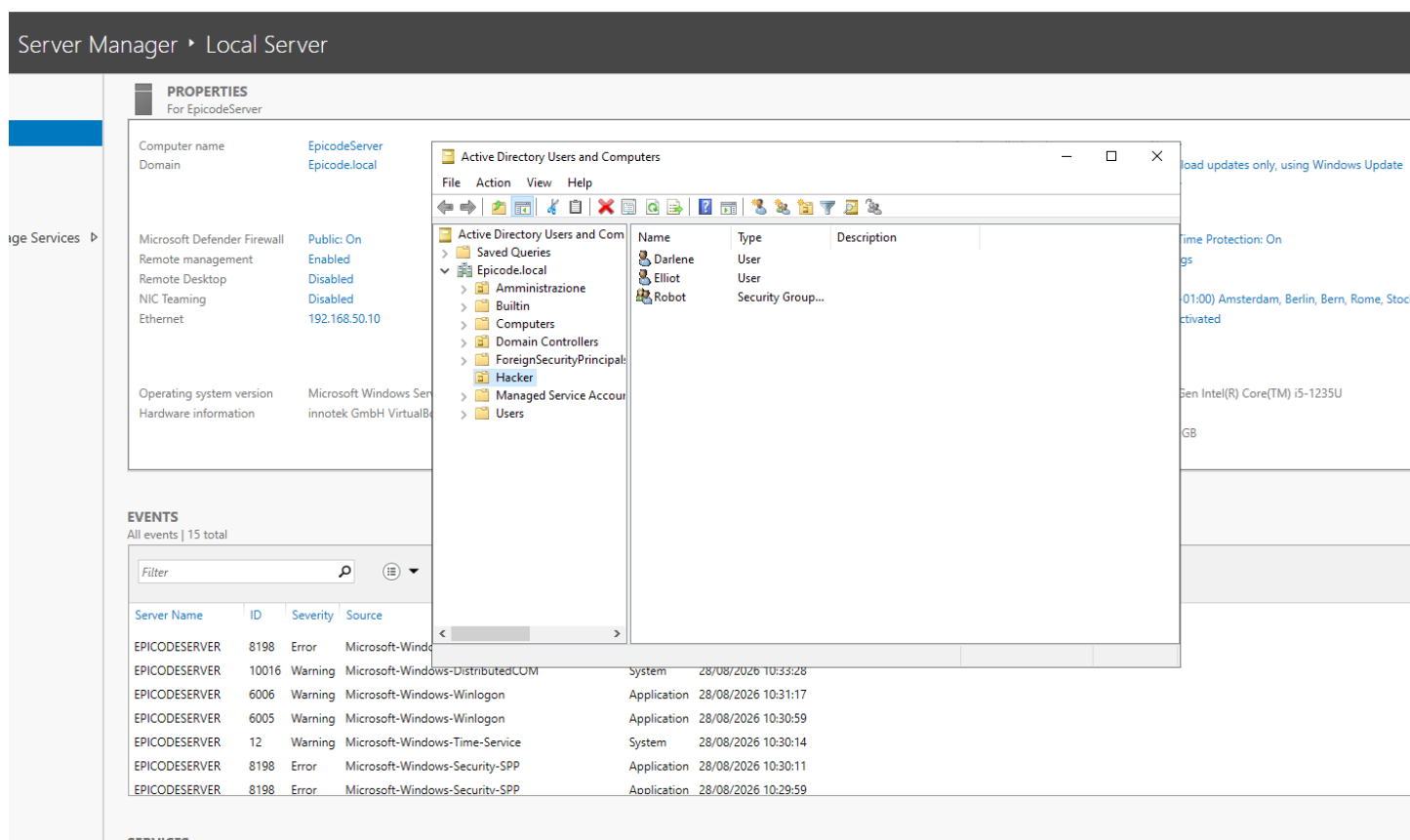


Fig. 1 – Accesso alla console Active Directory Users and Computers su EpicodeServer, con visibilità delle unità organizzative del dominio Epicode.local.

3. Nomi dei Gruppi Creati e Profilazione degli Utenti

All'interno del dominio Active Directory sono stati definiti due gruppi di sicurezza di tipo Global (Security Group – Global scope), strutturati per rispecchiare i ruoli organizzativi aziendali:

3.1 Gruppo Amministrazione / Direzione

- Utenti associati: Ambrogio e Gelsomina.
- Funzione e ruolo: gestione strategica, amministrativa e di governance dell'intera organizzazione, con visibilità e controllo estesi su tutte le risorse aziendali.

3.2 Gruppo Marketing Team (Marketing_Team)

- Utenti associati: Igor (Igor) e Victor (Victor Frankenstein).
- Funzione e ruolo: gestione delle attività operative e di marketing, con accessi mirati e limitati esclusivamente alle risorse di reparto.

4. Passaggi Seguiti per Creare e Configurare i Gruppi

L'intera configurazione è stata eseguita nativamente tramite gli strumenti di amministrazione di Active Directory, seguendo i passaggi descritti di seguito.

4.1 Creazione dei Gruppi in Active Directory

Dalla console "Active Directory Users and Computers", tramite il menu contestuale New > Group, sono stati creati i gruppi di sicurezza richiesti (scope Global, tipo Security), tra cui il gruppo Marketing, mantenendo separata l'unità organizzativa "Amministrazione" già predisposta per la Direzione.

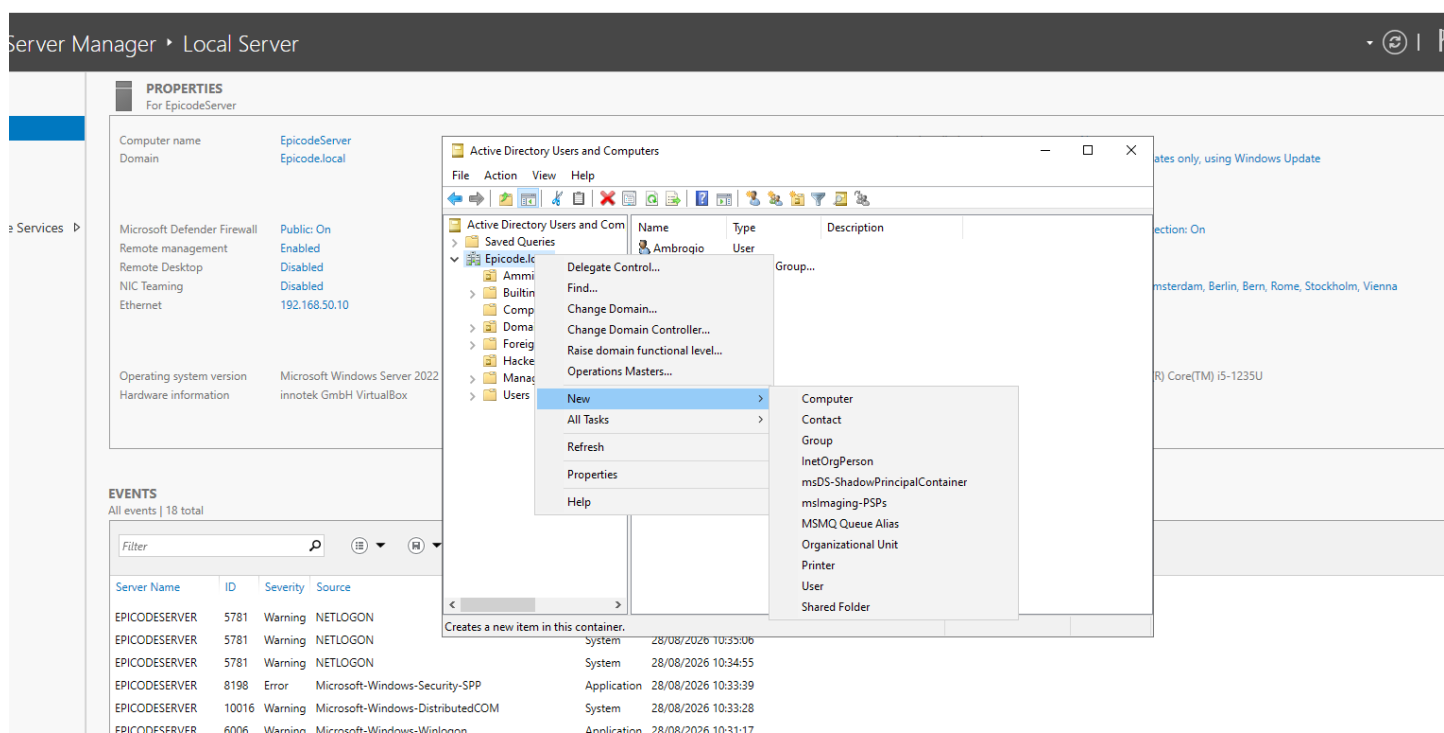


Fig. 2 – Creazione di un nuovo oggetto (Gruppo o Utente) all'interno del dominio Epicode.local tramite il menu contestuale New.

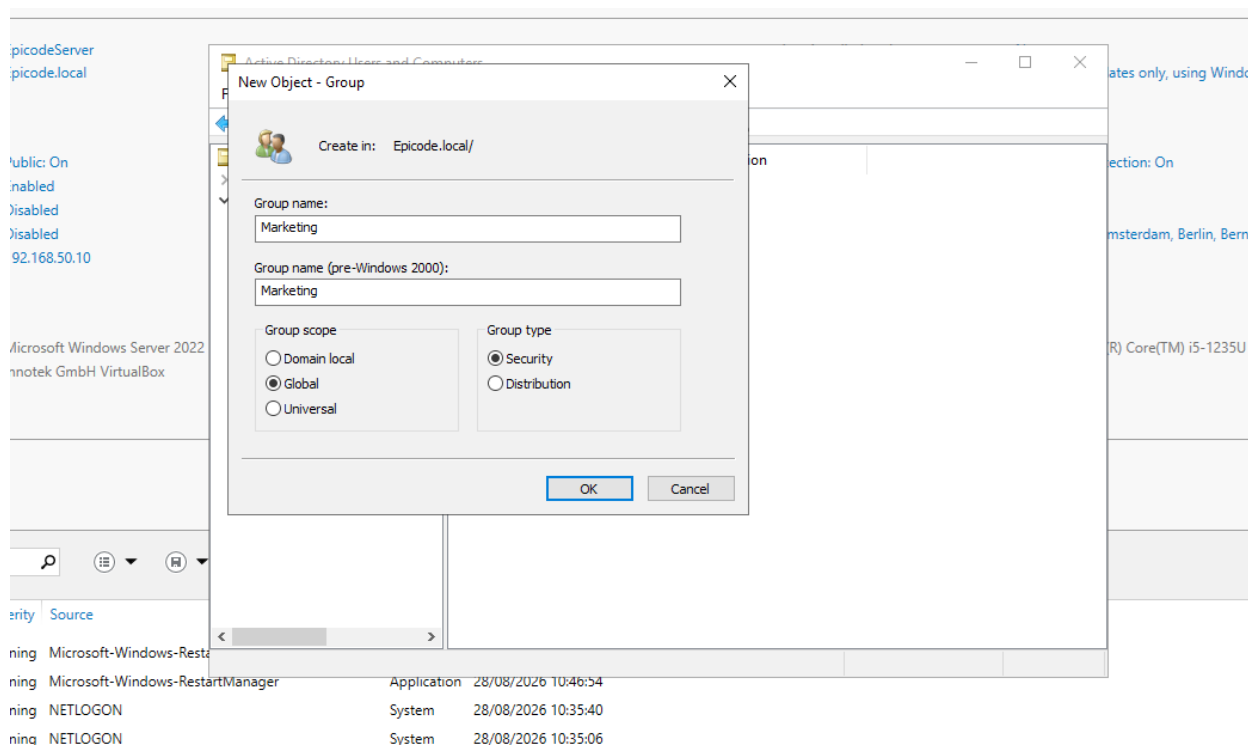


Fig. 3 – Finestra di creazione del gruppo "Marketing", con scope Global e tipo Security.

4.2 Creazione e Associazione degli Utenti

Sono stati creati gli account utente di prova per i due reparti: Ambrogio e Gelsomina, inseriti nel gruppo/unità organizzativa di Direzione, e Igor e Victor (Victor Frankenstein), creati all'interno dell'unità organizzativa Marketing Team.

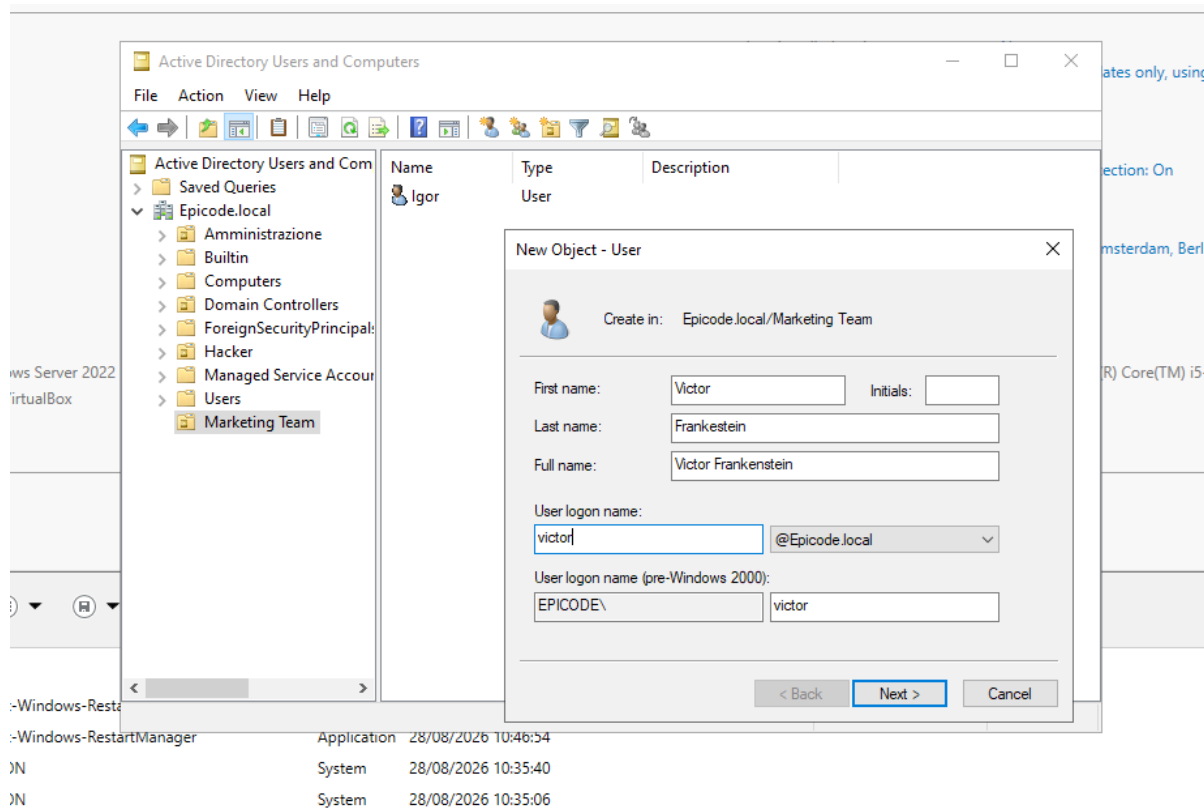


Fig. 4 – Creazione dell'utente Victor Frankenstein (login name: victor) nell'unità organizzativa Marketing Team.

Successivamente, gli utenti Igor e Victor sono stati associati al gruppo di sicurezza Marketing tramite la selezione del gruppo nella finestra "Select Groups" (scheda di appartenenza – Member of).

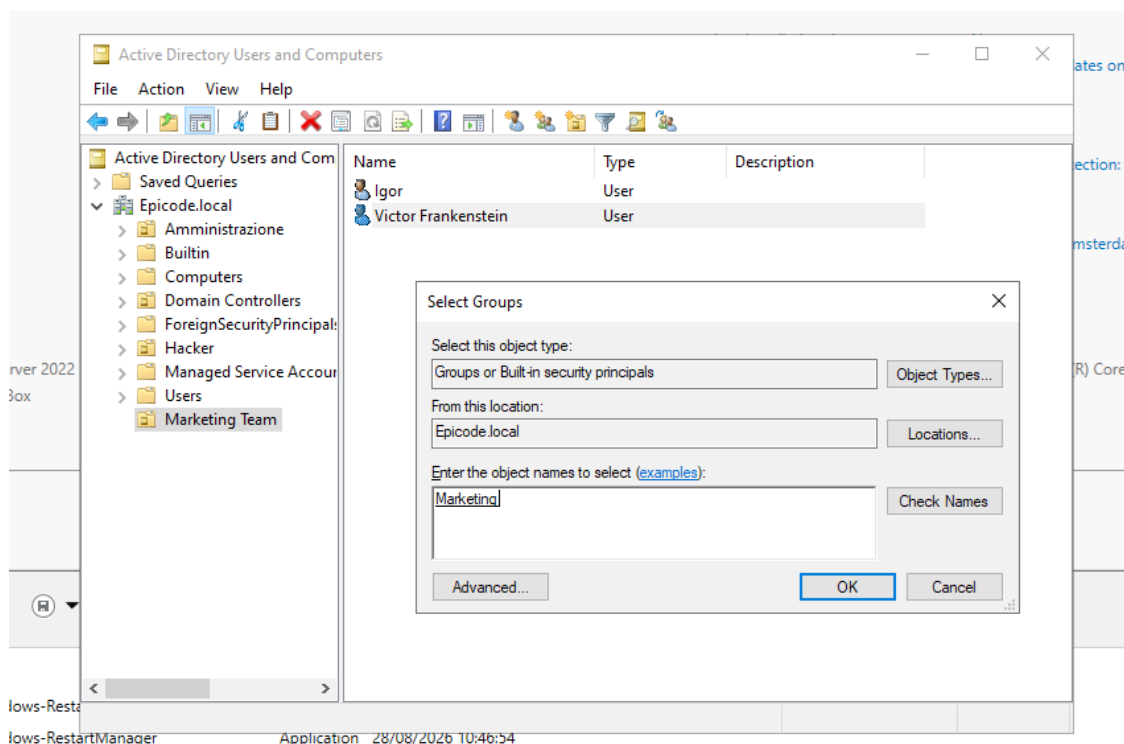


Fig. 5 – Aggiunta degli utenti Igor e Victor Frankenstein al gruppo di sicurezza Marketing.

4.3 Integrazione dei Client nell'Infrastruttura

Le workstation di prova sono state unite al dominio Active Directory (Epicode.local) per consentire l'autenticazione centralizzata degli utenti e la corretta applicazione delle policy di sicurezza definite a livello di dominio.

4.4 Configurazione dei Permessi (Condivisioni e NTFS)

È stata creata la cartella condivisa Marketing_Shared sul disco locale (C:) del server, condivisa in rete con nome di condivisione "Marketing_Shared". A livello di Permessi di condivisione (Share Permissions), al gruppo Marketing sono stati assegnati i permessi di Full Control, Change e Read.

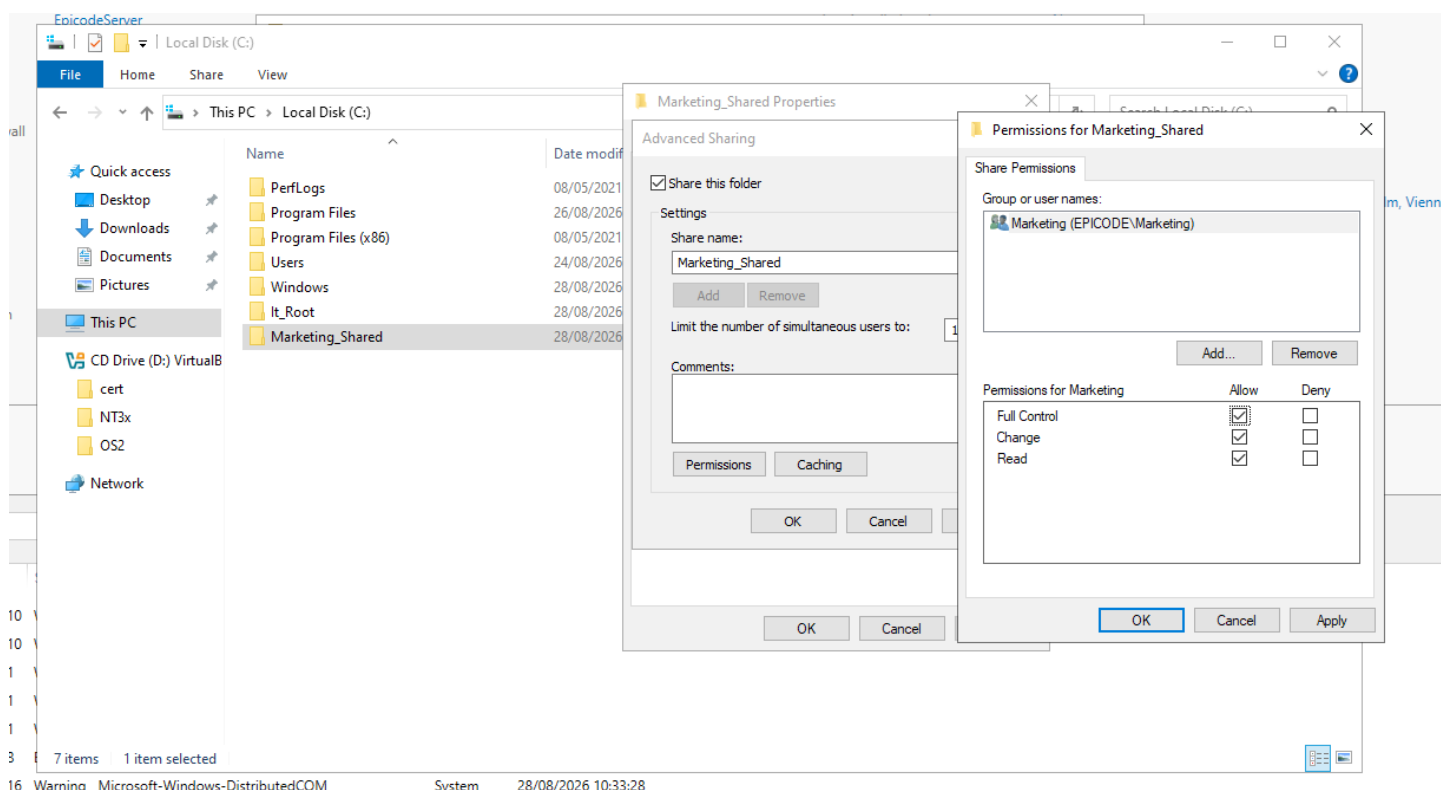


Fig. 6 – Condivisione della cartella *Marketing_Shared* e assegnazione dei permessi di condivisione (Share Permissions) al gruppo Marketing.

A livello di sicurezza NTFS (scheda Security), sulla stessa cartella sono stati configurati permessi differenziati per gruppo/utente: al gruppo Marketing sono stati concessi i permessi di Read & Execute, List folder contents, Read e Write, in modo da consentire la piena operatività sui soli file di reparto, escludendo qualsiasi accesso alle cartelle riservate all'Amministrazione.

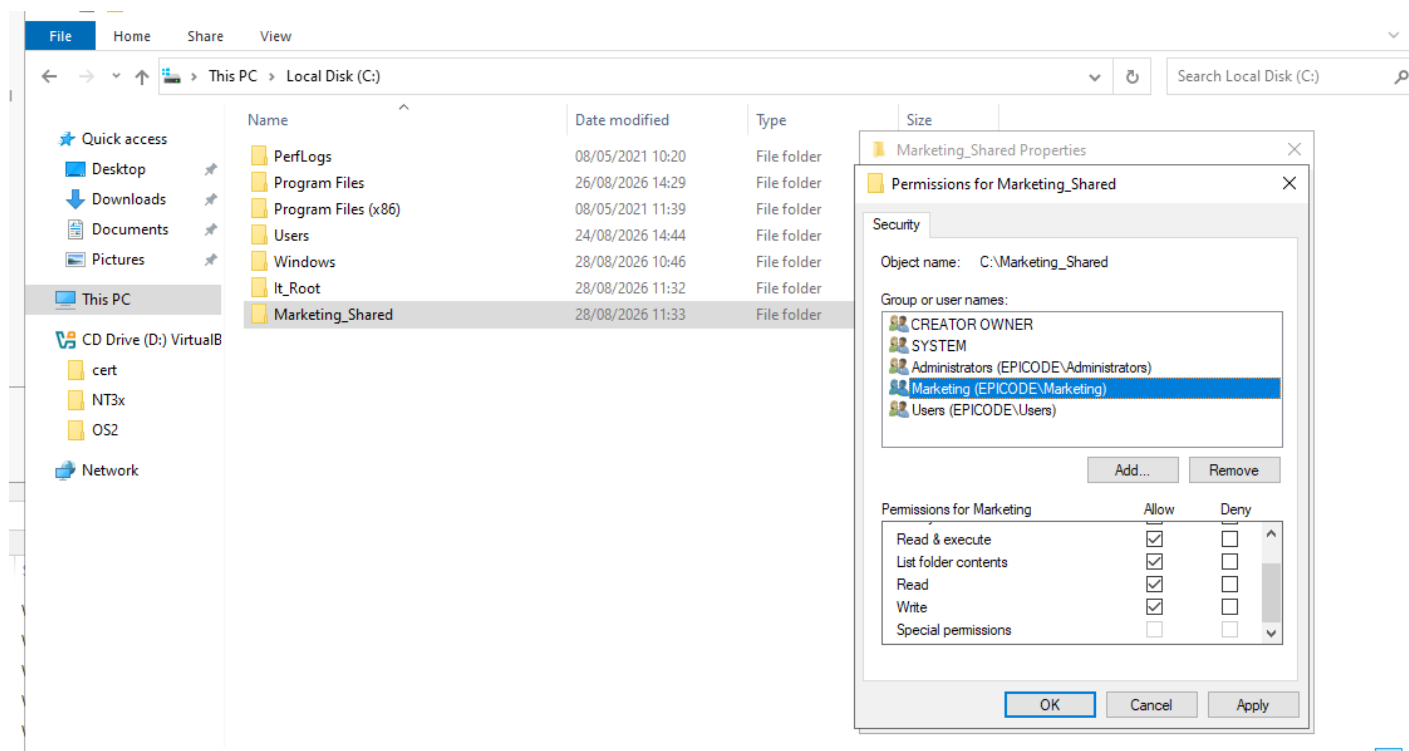


Fig. 7 – Permessi NTFS (scheda Security) sulla cartella *Marketing_Shared*, con elenco dei gruppi/utenti abilitati (Marketing, Administrators, SYSTEM, Users).

4.5 Configurazione dei Criteri di Gruppo (GPO)

Per limitare le modifiche alle impostazioni di sistema da parte degli utenti del reparto Marketing, è stato creato e collegato all'unità organizzativa Marketing Team un oggetto Criteri di Gruppo denominato GPO-Restrizioni-Marketing. All'interno della sezione User Configuration > Administrative Templates > Control Panel, è stata abilitata l'impostazione "Prohibit access to Control Panel and PC settings", che impedisce l'avvio del Pannello di controllo e dell'app Impostazioni PC.

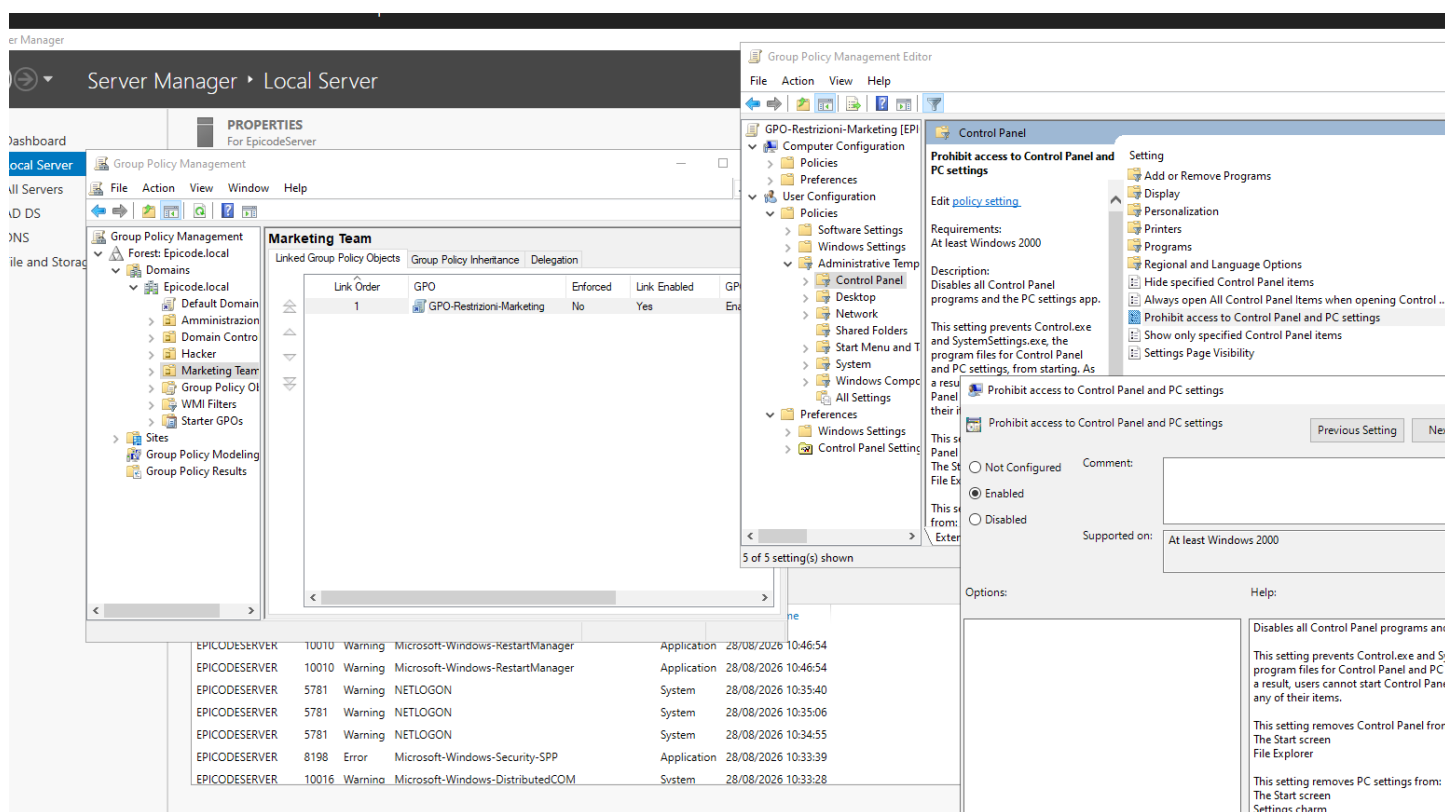


Fig. 8 – Group Policy Management Editor: configurazione della GPO "GPO-Restrizioni-Marketing" collegata all'unità organizzativa Marketing Team, con l'impostazione "Prohibit access to Control Panel and PC settings" impostata su Enabled.

Per quanto riguarda l'accesso remoto al server, è stata modificata la Default Domain Controllers Policy nella sezione Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > User Rights Assignment, impostando esplicitamente il diritto "Allow log on through Remote Desktop Services" ai soli gruppi Administrators e ai gruppi con effettiva necessità operativa, inserendo il gruppo Marketing solo dove strettamente richiesto per l'accesso alle workstation client e non ai controller di dominio.

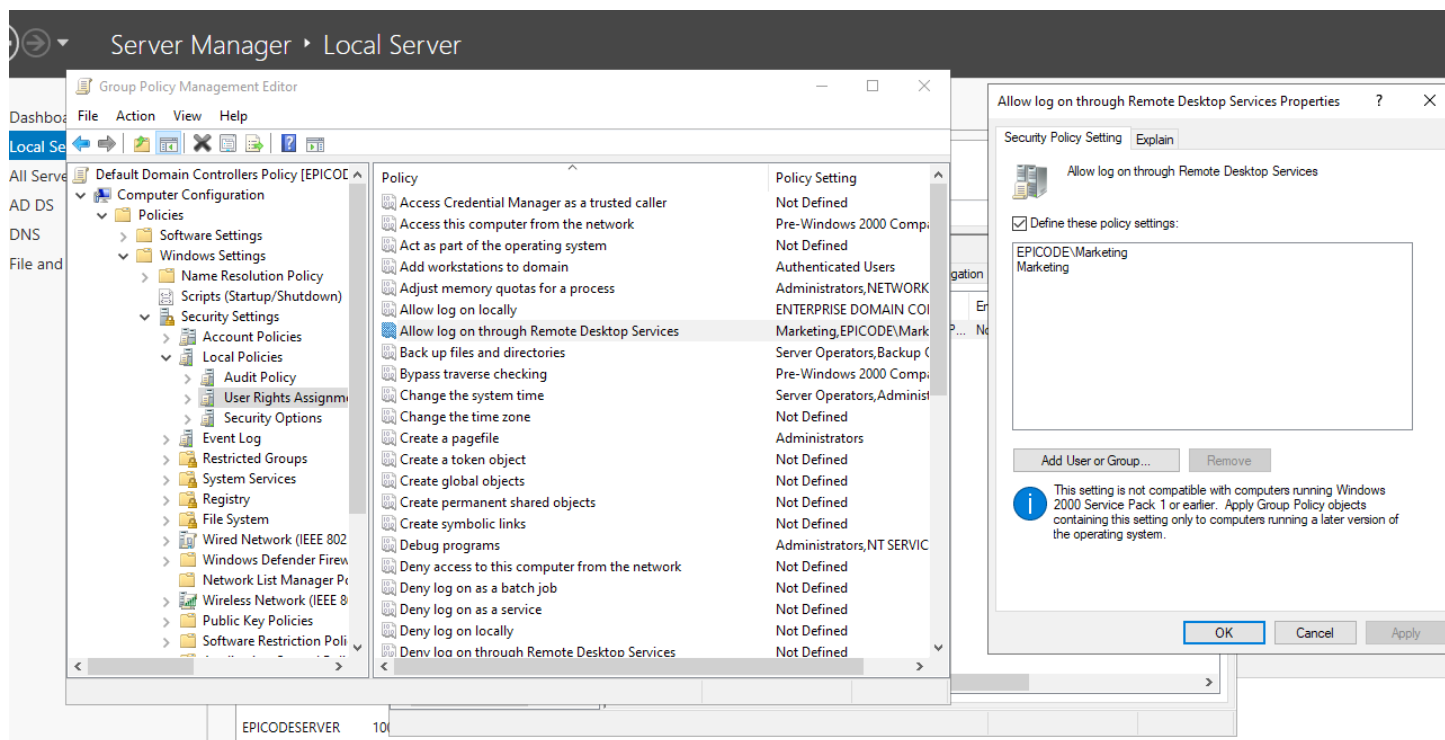


Fig. 9 – Configurazione del diritto utente "Allow log on through Remote Desktop Services" nella Default Domain Controllers Policy.

Infine, per rendere immediatamente effettive le modifiche apportate ai Criteri di Gruppo senza attendere il normale ciclo di aggiornamento (background refresh), è stato eseguito da PowerShell il comando `gpupdate /force` sul server, che ha aggiornato correttamente sia i criteri Computer sia i criteri User.

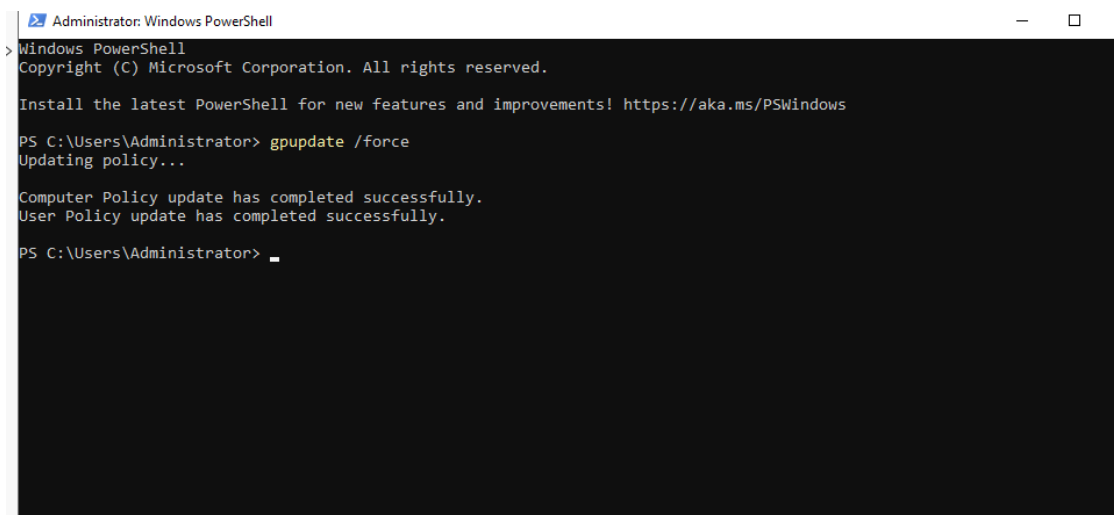


Fig. 10 – Esecuzione del comando `gpupdate /force` da Windows PowerShell per forzare l'applicazione immediata dei Criteri di Gruppo.

5. Permessi Assegnati a Ciascun Gruppo e Giustificazione

Per ciascun gruppo sono stati configurati permessi specifici in base alle quattro macro-aree di sicurezza richieste: accesso a file e cartelle, esecuzione di programmi, modifiche alle impostazioni di sistema e accesso remoto al server. La tabella seguente riassume le scelte effettuate.

Aspetto di sicurezza	Gruppo Amministrazione / Direzione (Ambrogio, Gelsomina)	Gruppo Marketing_Team (Igor, Victor)
Accesso a file e cartelle	Controllo completo (Full Control) su tutte le condivisioni di rete, inclusi dati amministrativi, finanziari e riservati.	Accesso in lettura/scrittura limitato esclusivamente alla cartella condivisa di reparto (Marketing_Shared).
Esecuzione programmi	Illimitata, con accesso a software gestionali, di contabilità, strumenti di amministrazione e di produttività.	Limitata alle applicazioni di produttività (Office, browser, tool grafici); bloccati gli eseguibili di sistema non necessari.
Modifiche impostazioni di sistema	Consentite, necessarie per la supervisione, la manutenzione e la configurazione di postazioni e servizi.	Negate tramite Criteri di Gruppo (GPO-Restrizioni-Marketing), per impedire alterazioni accidentali o manomissioni delle configurazioni locali.
Accesso remoto al server	Consentito (tramite Desktop Remoto e strumenti di gestione remota) per la governance dell'infrastruttura.	Negato verso i server critici; l'accesso è consentito unicamente sulle normali workstation client del dominio.

5.1 Giustificazione delle Scelte

Perché il gruppo Amministrazione / Direzione ha pieni poteri? Trattandosi di ruoli di vertice e di controllo aziendale, Ambrogio e Gelsomina necessitano di poter operare senza colli di bottiglia tecnici, avendo visibilità globale e poteri di intervento tempestivo su server e dati.

Perché il Marketing_Team ha restrizioni rigorose? Igor e Victor operano in un settore non sistemistico; limitare i permessi di esecuzione, inibire le modifiche al sistema operativo e bloccare l'accesso remoto ai server critici riduce drasticamente i vettori di rischio informatico, ad esempio infezioni da malware derivanti da eseguibili non controllati, oppure errori umani di configurazione.

6. Verifica della Correttezza delle Impostazioni

Prima di validare l'ambiente per l'uso produttivo, sono stati effettuati test pratici mirati, creando gli utenti di prova illustrati in precedenza e verificandone il comportamento in base al gruppo di appartenenza.

6.1 Verifica dell'autenticazione

L'accesso eseguito con gli utenti di prova (Victor e Igor) sulle workstation del dominio è andato a buon fine, confermando la correttezza delle credenziali centralizzate in Active Directory e la corretta unione delle postazioni al dominio Epicode.local.

6.2 Verifica delle restrizioni di sistema (GPO)

Tentando di aprire le impostazioni di sistema protette (Pannello di controllo / Impostazioni PC) con un account del gruppo Marketing, il sistema ha bloccato l'accesso in linea con l'impostazione "Prohibit access to Control Panel and PC settings" applicata tramite GPO, provando l'efficacia della policy dopo l'esecuzione del comando gpupdate /force.

6.3 Verifica delle risorse e dei permessi (ACL)

- Gli utenti del marketing (Victor e Igor) hanno dimostrato di poter leggere e scrivere regolarmente all'interno della cartella di reparto Marketing_Shared, ricevendo invece un errore di accesso negato (Access Denied) nel tentativo di accedere alle directory riservate all'amministrazione.
- Gli utenti della Direzione (Ambrogio e Gelsomina) hanno verificato con successo il pieno controllo su tutte le condivisioni aziendali, coerentemente con i permessi di Full Control assegnati.

7. Conclusioni

L'implementazione descritta ha permesso di strutturare in modo ordinato e sicuro la gestione degli utenti e delle risorse aziendali all'interno del dominio Active Directory Epicode.local. La suddivisione in gruppi di sicurezza (Amministrazione/Direzione e Marketing_Team), unita all'applicazione di permessi differenziati su condivisioni NTFS e Criteri di Gruppo, ha consentito di rispettare il principio del minimo privilegio, riducendo la superficie di attacco e garantendo al contempo la piena operatività dei ruoli di vertice aziendale.

I test di verifica condotti confermano la correttezza della configurazione: gli utenti di reparto operano esclusivamente entro il perimetro di risorse loro assegnato, mentre il personale di Direzione mantiene la visibilità e il controllo necessari alla gestione strategica dell'infrastruttura.